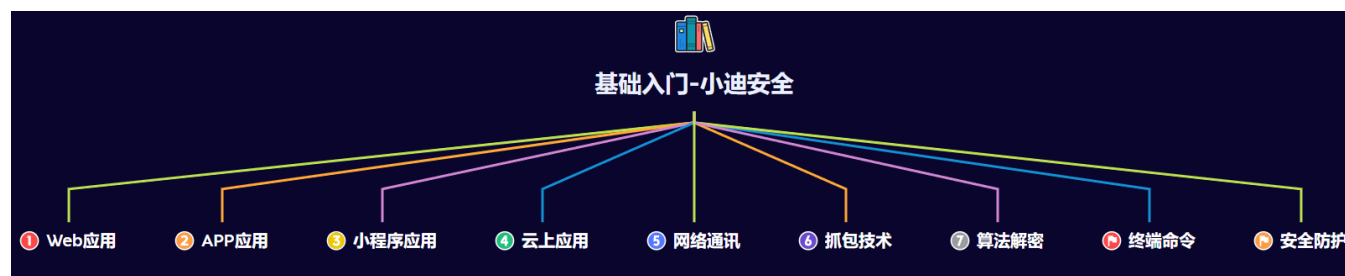


# Day04 基础入门-Web应用&蜜罐系统&堡垒机运维&API内外接口&第三方拓展架构&部署影响



## 1.知识点

- 1、基础入门-Web应用-域名上的技术要点
- 2、基础入门-Web应用-源码上的技术要点
- 3、基础入门-Web应用-数据上的技术要点
- 4、基础入门-Web应用-解析上的技术要点

- 
- 1、基础入门-Web应用-搭建架构上的技术要点
  - 2、基础入门-Web应用-源码类别上的技术要点

- 
- 1、基础入门-Web应用-防护产品-WAF保护
  - 2、基础入门-Web应用-加速服务-CDN节点
  - 3、基础入门-Web应用-文件托管-OSS存储
  - 4、基础入门-Web应用-通讯服务-反向代理
  - 5、基础入门-Web应用-运维安全-负载均衡

- 
- 1、基础入门-Web应用-蜜罐系统
  - 2、基础入门-Web应用-堡垒机运维
  - 3、基础入门-Web应用-内外API接口
  - 4、基础入门-Web应用-第三方拓展架构

## 2.详细点

- 架构：WEB,APP,小程序,前后端,容器化等
- 服务：OSS存储,CDN加速,云数据库,负载均衡等
- 网络：不回显,反向代理,防火墙出入站,内外网,正反向连接等
- 算法：MD5,Base64,AES,DES,Salt,自定义,代码加密算法等

- 命令：Windows&Linux,文件下载,网络查看,反弹权限,用户等
- 防护：WAF防护,蜜罐系统,CDN加速,权限设置,加壳加密反调试等

### 3.演示案例

#### 3.1 Web-拓展应用-蜜罐-钓鱼诱使

1

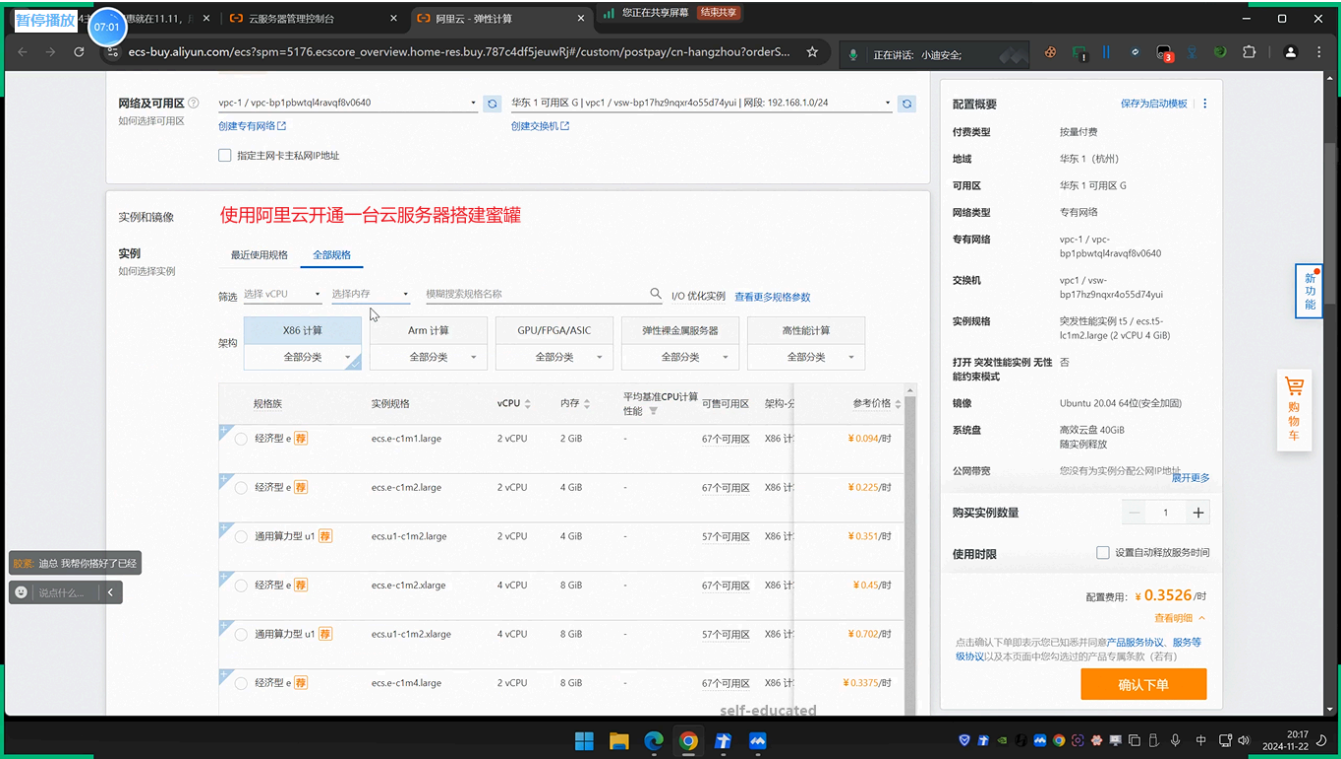
测试系统：Ubuntu 20.04

2

一键安装：bash <(curl -ss -L https://hfish.net/webinstall.sh)

3

有害影响：用来钓鱼或诱惑测试人员的防护系统



```
test - root@iZbp1aqlc2sqtq6y8310r9Z: ~ - Xshell 5
Xshell (Build N/A)
Copyright (c) 2002-2016 NetSarang Computer, Inc. All rights reserved.

Type 'help' to learn how to use Xshell prompt.
[c:\~]$

Connecting to 47.97.33.216:22...
Could not connect to '47.97.33.216' (port 22): Connection failed.

Type 'help' to learn how to use Xshell prompt.
[c:\~]$

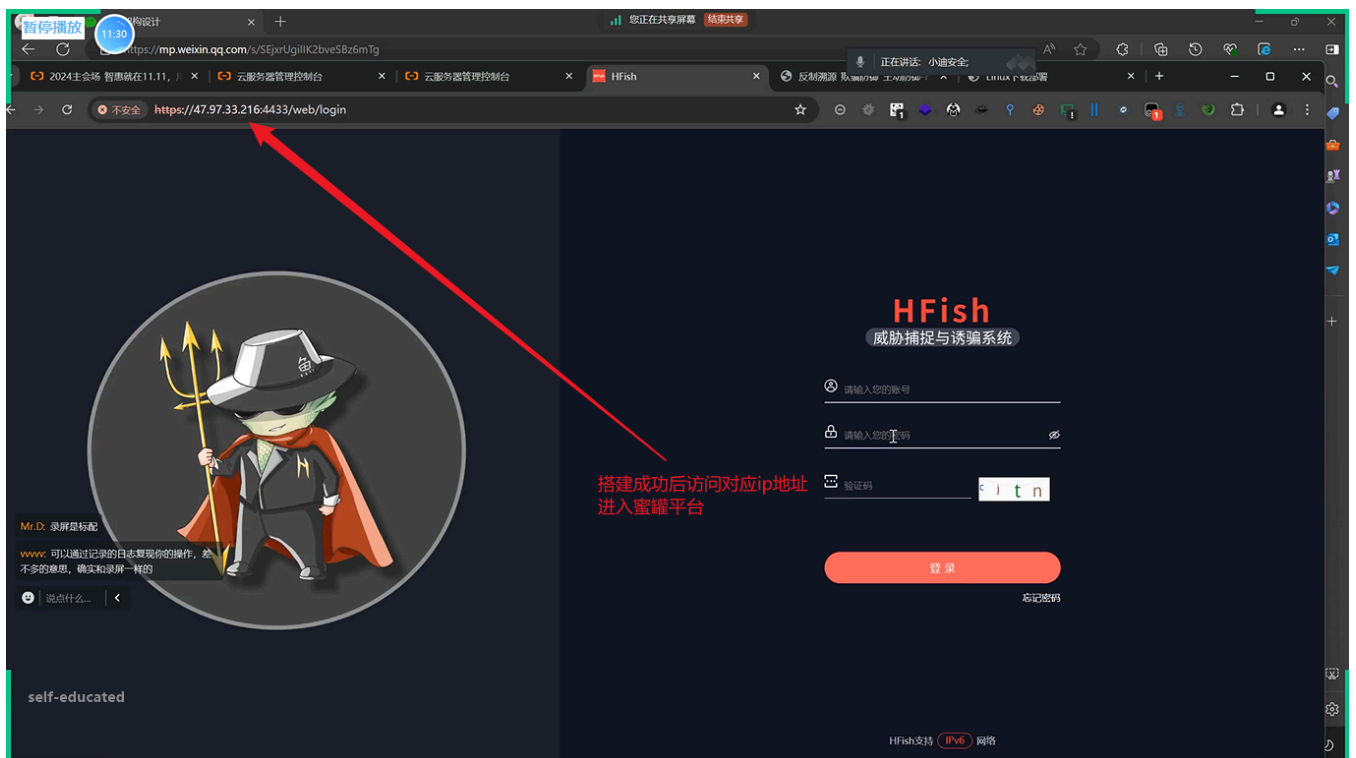
Connecting to 47.97.33.216:22...
Connection established.
To escape to local shell, press 'Ctrl+Alt+J'.

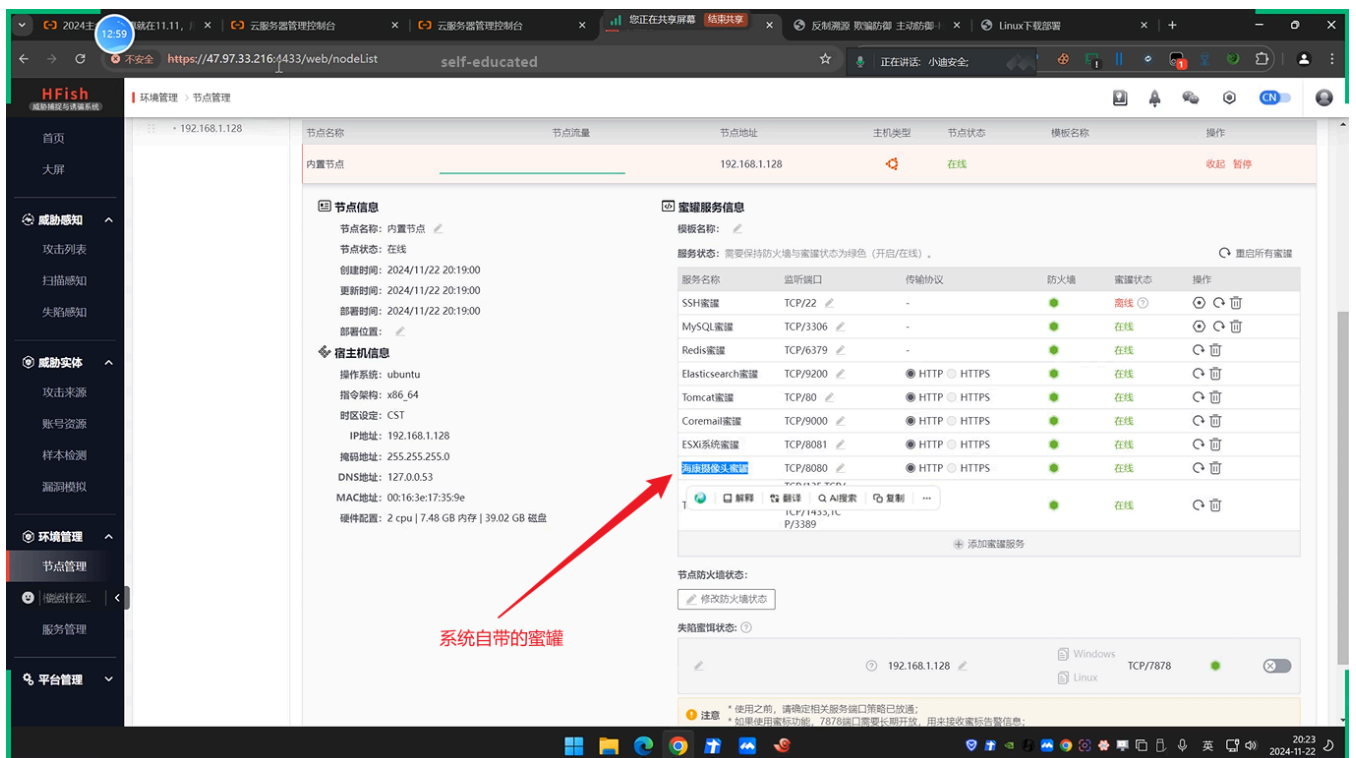
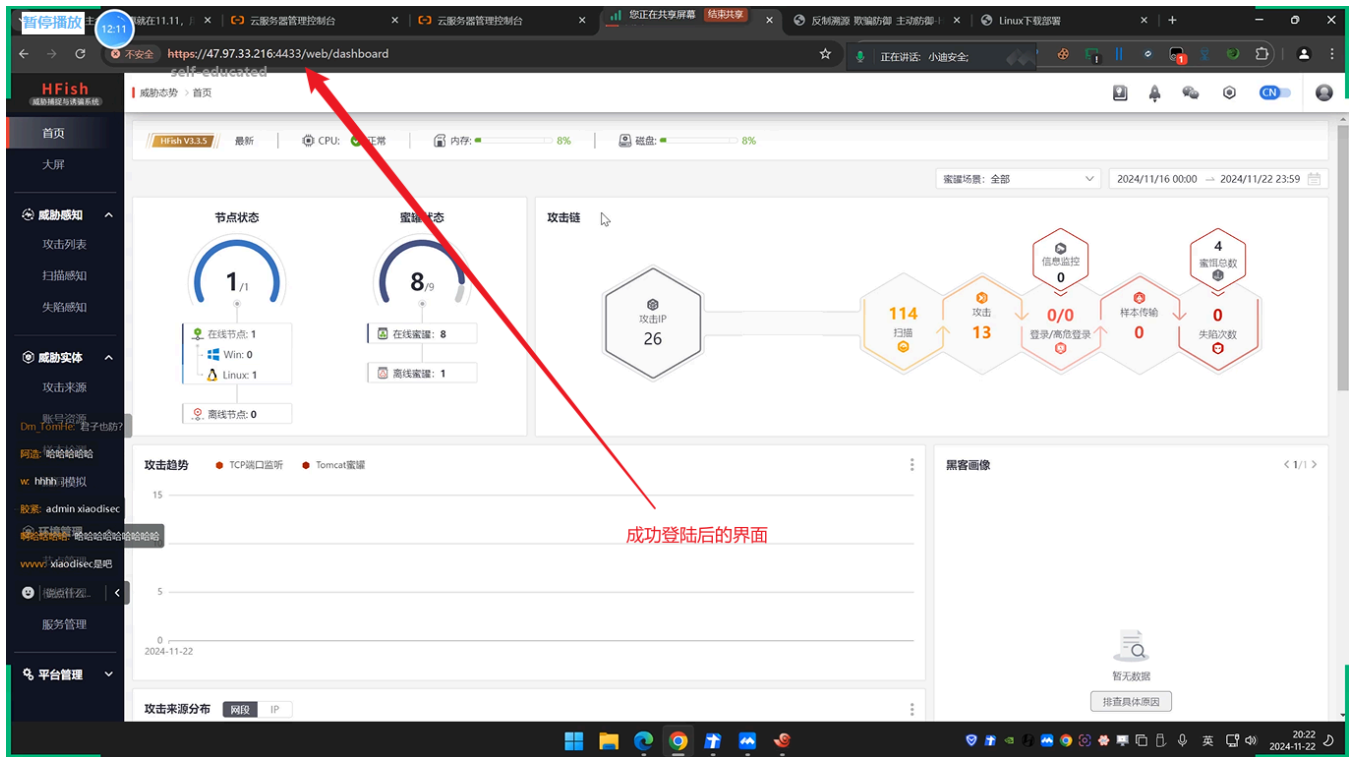
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-198-generic x86_64)

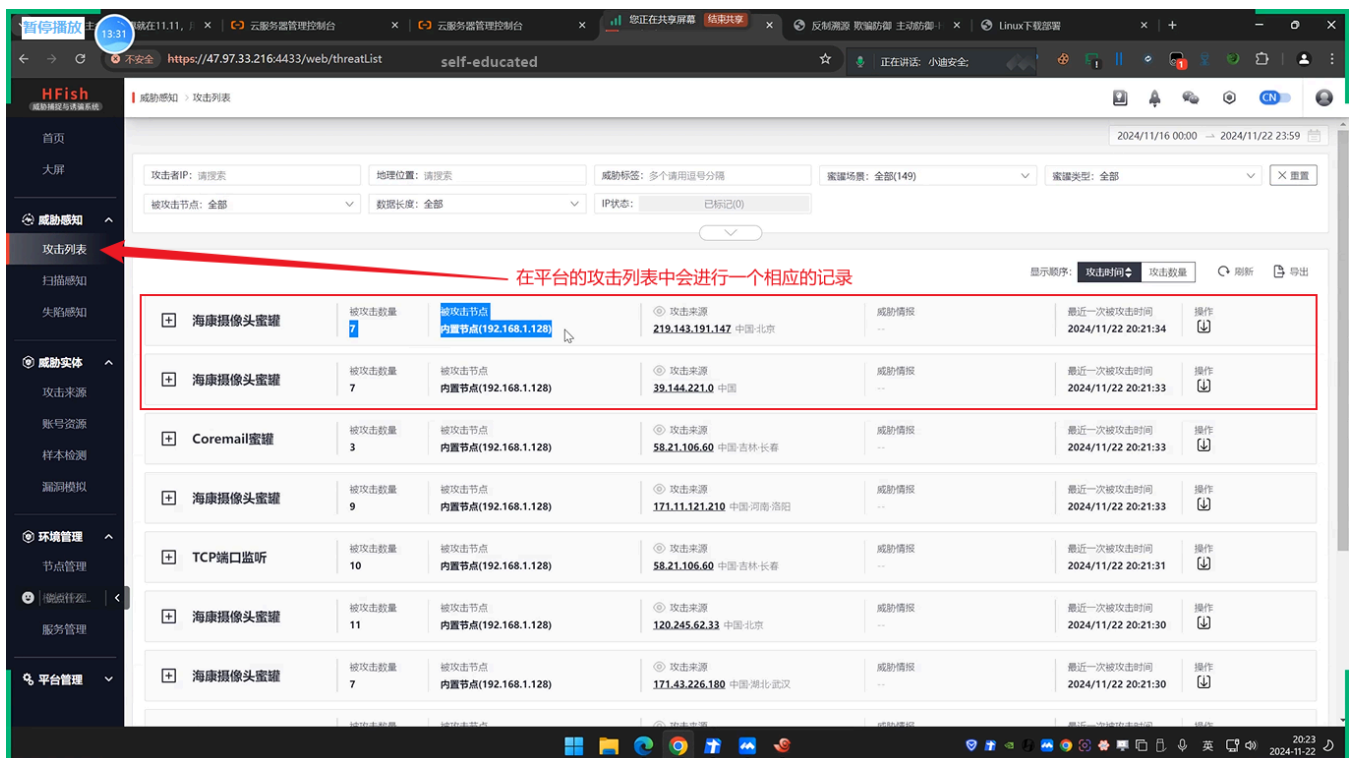
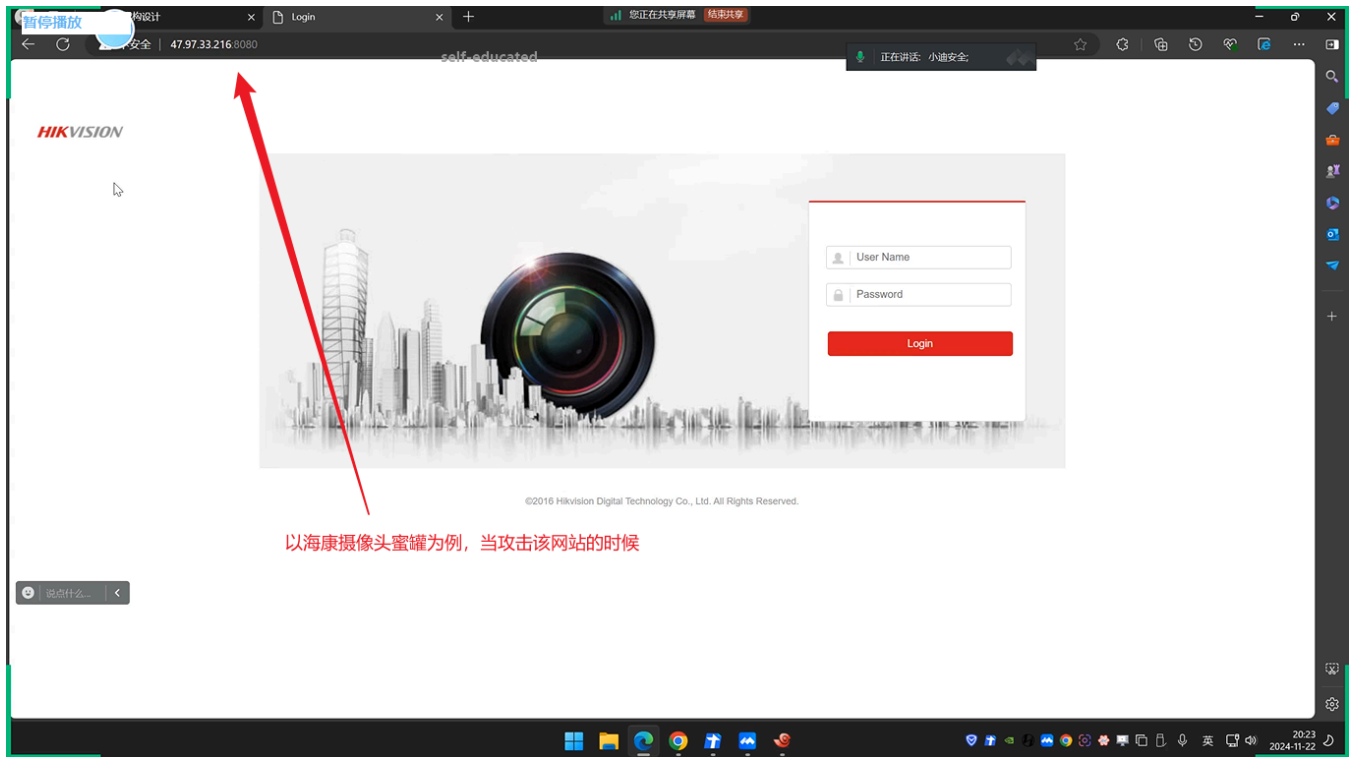
 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Welcome to Alibaba Cloud Elastic Compute Service !

root@iZbp1aqlc2sqtq6y8310r9Z:~# bash <(curl -sS -L https://hfish.net/webinstall.sh) 使用该命令搭建hifish蜜罐
```







### 3.2 Web-拓展应用-堡垒机-突破口

- 测试系统: Ubuntu 20.04
- 一键安装: `curl -sSL https://resource.fit2ccloud.com/jumpserver/jumpserver/releases/latest/download/quick_start.sh | bash`
- 有利影响: web应用或其他应用提供给测试人员一个能获取到价值信息的系统



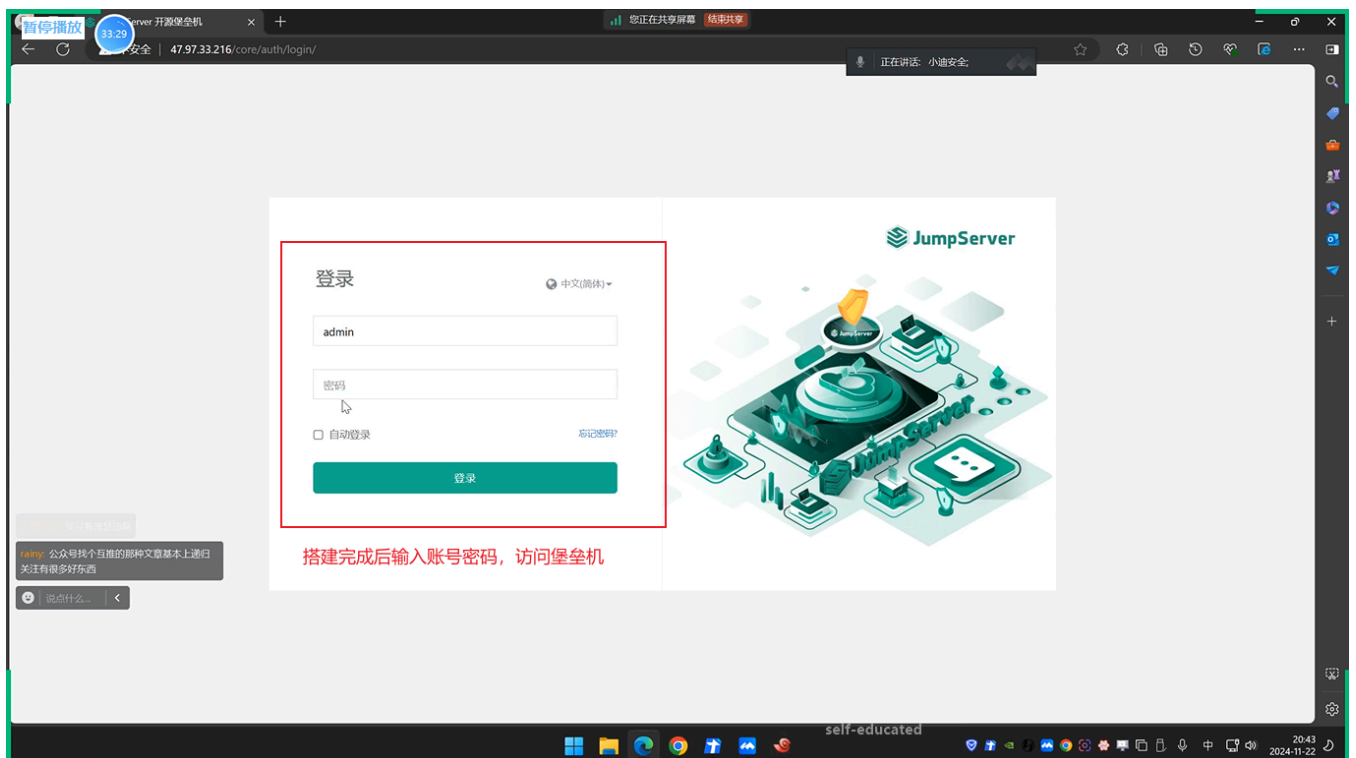
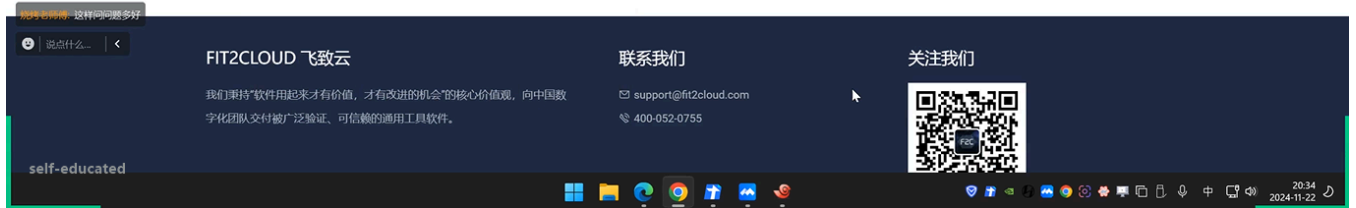
## 在线安装

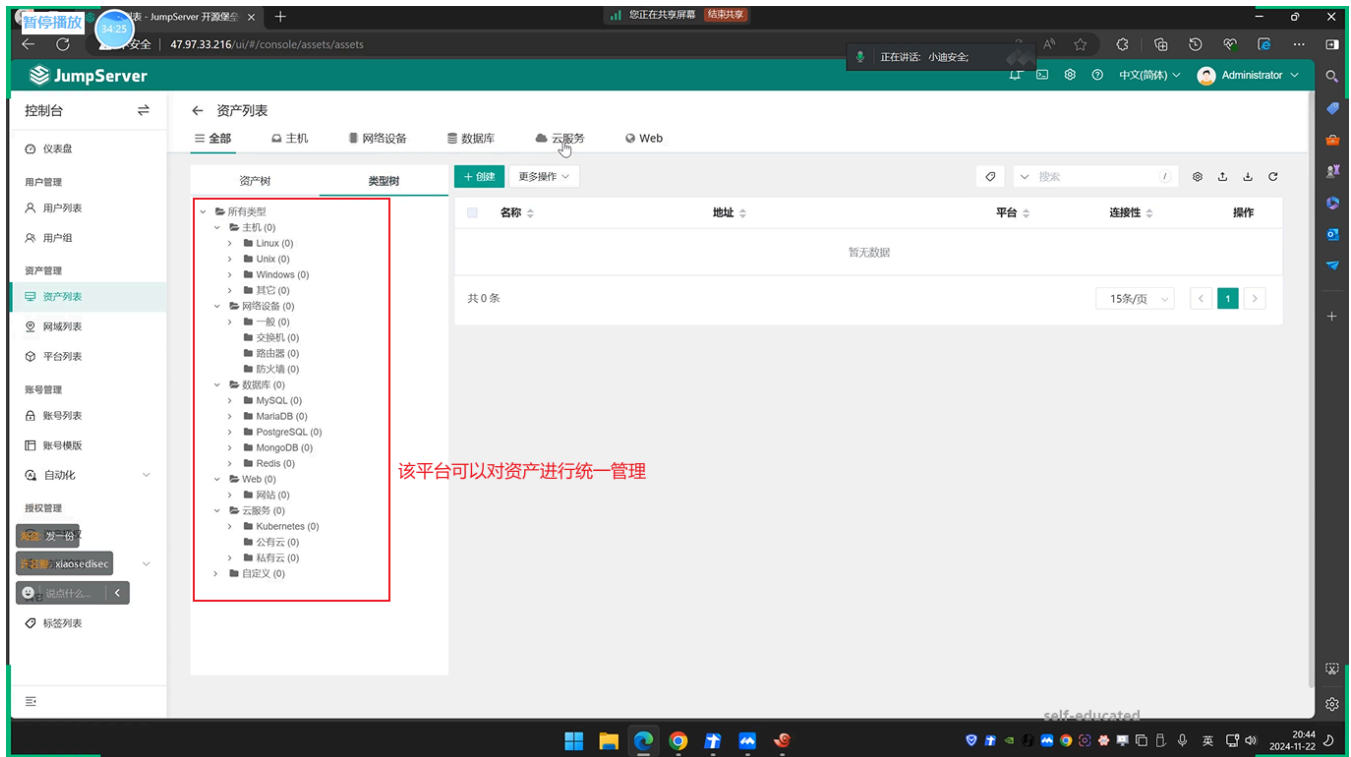
仅需两步快速安装 JumpServer:

准备一台 4核8G (最低) 且可以访问互联网的 64 位 Linux 主机;  
以 root 用户执行如下命令一键安装 JumpServer。

```
curl -sSL https://resource.fit2cloud.com/jumpserver/releases/latest/download/quick_start.sh | bash
```

使用阿里云开通一台云服务器，使用该命令一键安装jumpserver





### 3.3 Web-拓展应用-API接口-突破口

1 定义了一组规则和协议，软件开发人员可以使用这些规则和协议来访问操作系统、库、服务或其他应用程序的功能。

2 1、Web API：

3 通过HTTP协议进行通信的API，常用于web服务和应用程序。

4 例如，RESTful API、GraphQL API。

6 2、库和框架API：

7 提供特定编程语言或框架功能的API，供开发者在应用程序中使用。

8 例如，Java API、Python标准库。

10 3、操作系统API：

11 提供操作系统功能访问的API。

12 例如，windows API、POSIX API。

14 4、远程API：

15 允许在网络上远程访问服务的API。

16 例如，SOAP API、XML-RPC API。

18 例子：

19 内部API：比如我自己开发了一个收银系统，使用API接口可以查询到顾客数据，收入支付，销售提成等

20 外部API：比如我自己搭建了一个网站应用，功能需求有要借助到外部的资源，如地图，归属地，短信收发等

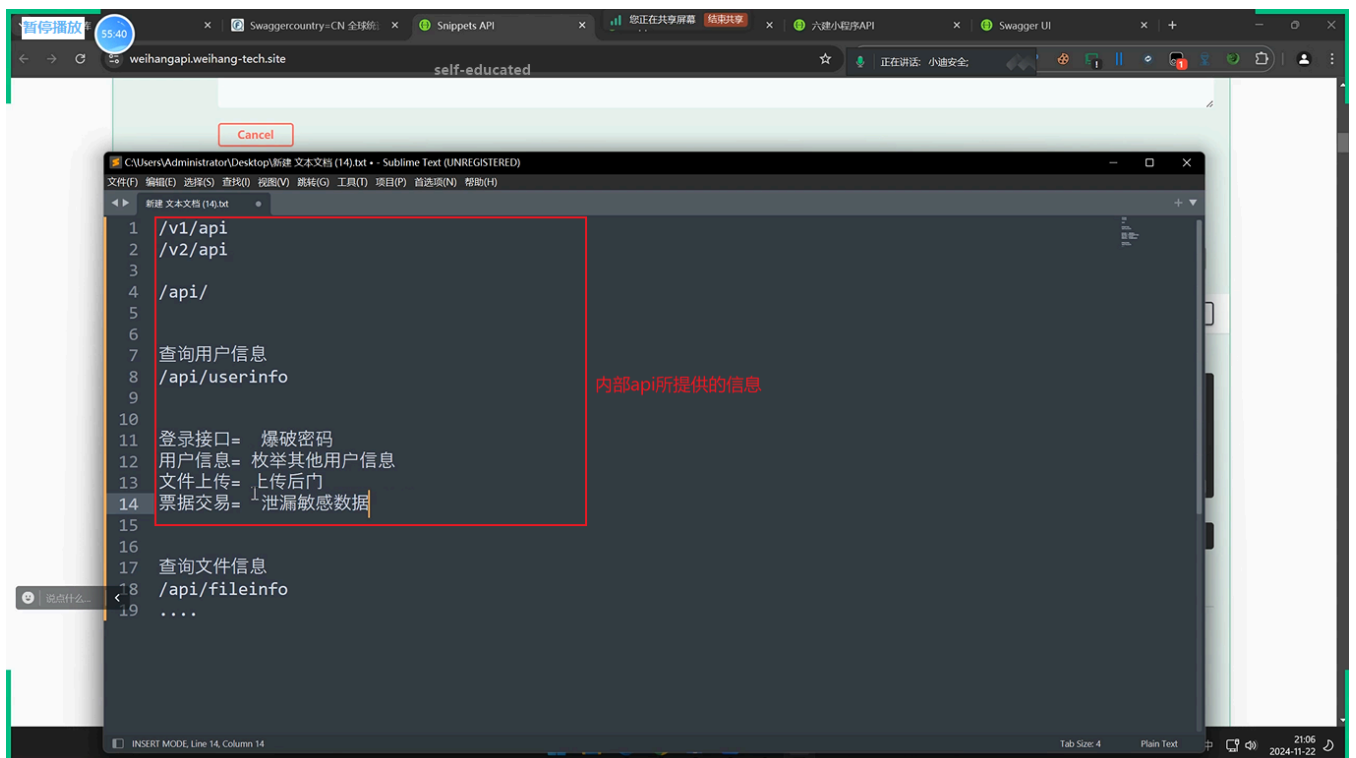
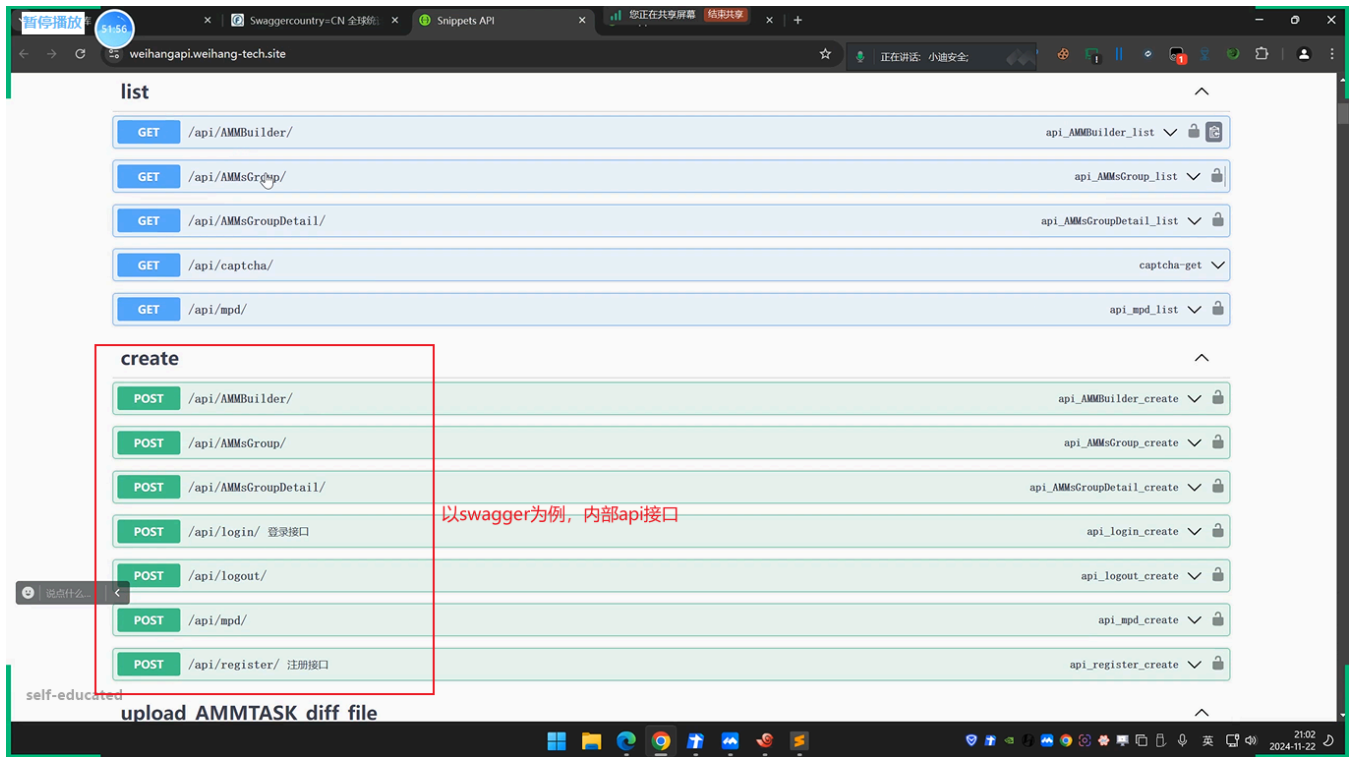
22 有利影响：

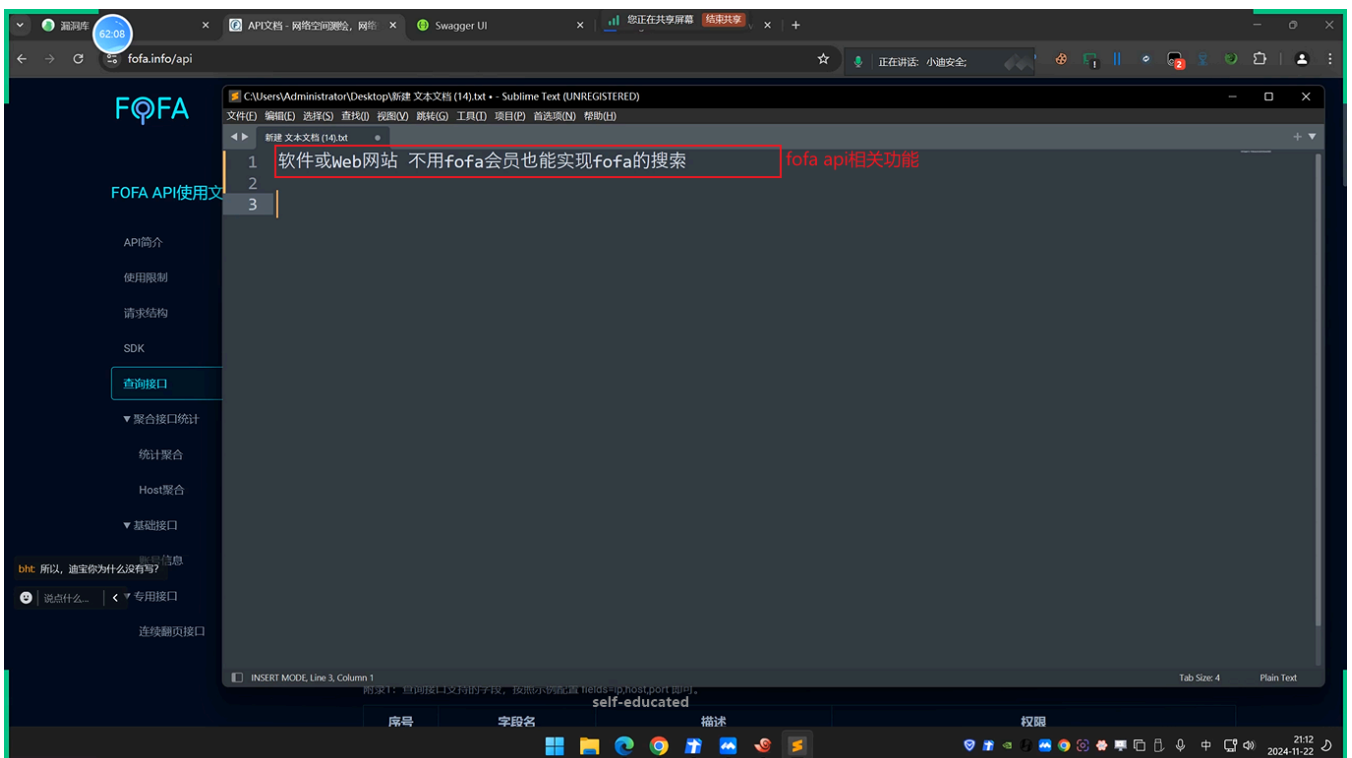
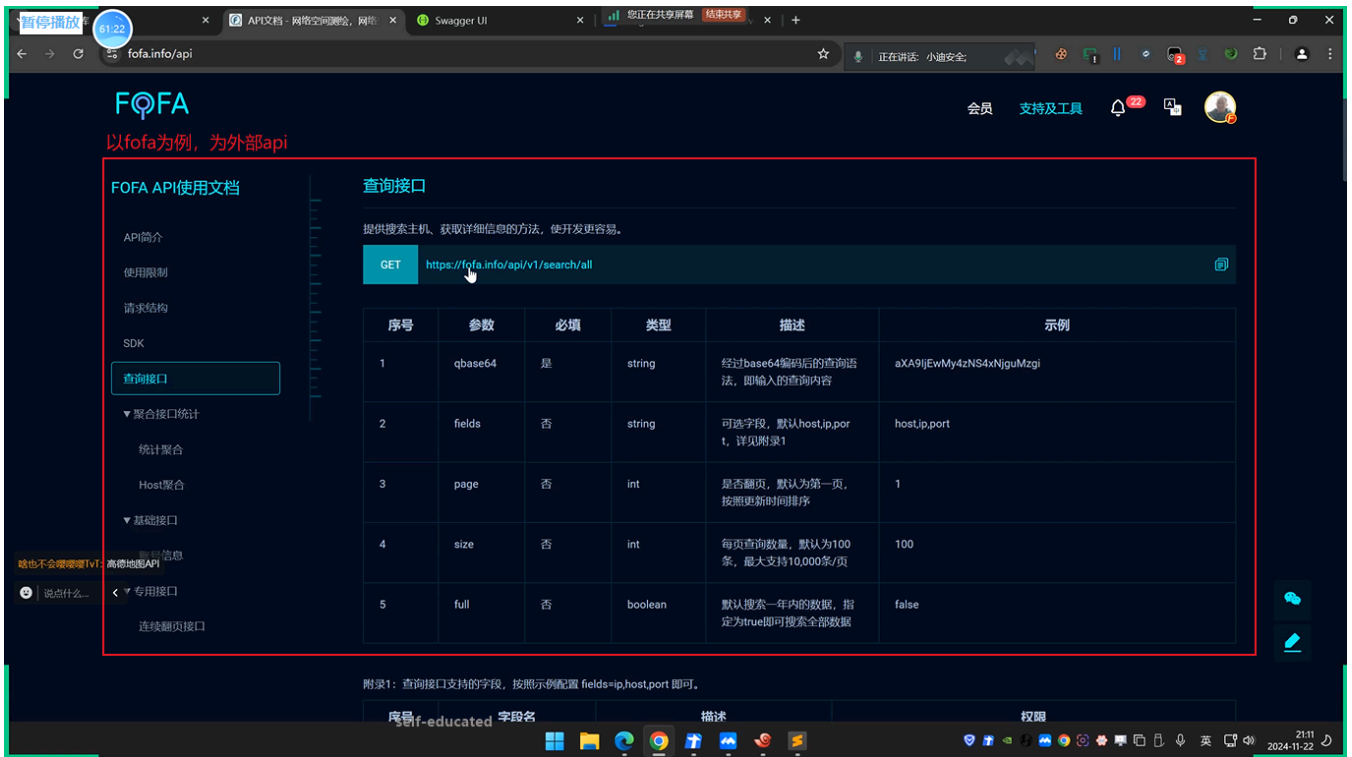
23 内部API：web应用提供给测试人员一个能获取到价值信息的接口

24 外部API：可以借助提供的API获取到当前网站不想让你获取的信息

25 分析API的目录结构、接口命名规则、参数命名规则、功能和业务逻辑等，

26 根据这些信息可以进行接口枚举和参数枚举，进而可以进行相关的漏洞测试。





### 3.4 Web-拓展应用-其他架构-突破口



- 1 ActiveMQ Redis Memcache Jenkins等漏洞
- 2 <https://mp.weixin.qq.com/s/SEjxrUgiIIK2bvesBz6mTg>
- 3 <https://www.yuque.com/u25571586/dyaqbugs?#> 密码: xnzx
- 4 有利影响：搭建越多应用即方便了运维也提供给测试人员更多机会

漏洞环境

还可以通过web的拓展架构作为突破口

ActiveMQ 反序列化漏洞

ActiveMQ 任意文件写入漏洞

Apache Airflow 示例dag中的命令注入

Apache Airflow Celery 消息中间件命令执行

Apache Airflow 默认密钥导致的权限绕过

Apache Druid 代码执行漏洞

Apereo CAS 4.1 反序列化命令执行漏洞

Apache APISIX 默认密钥漏洞

Apache APISIX Dashboard API权限绕过导致RCE

显示所有

RESET ALL FILTERS

AppActiveMQ CVECVE-2015-5254 Pathactivemq/CVE-2015-5254

ActiveMQ Deserialization Vulnerability (CVE-2015-5254)

中文版本(Chinese version)

Apache ActiveMQ is an open source messaging middleware developed by the American Pachitea (Apache) Software Foundation that supports Java messaging services, clustering, Spring framework, and more.

Apache ActiveMQ version 5.x before the 5.13.0 security vulnerability, the vulnerability caused by the program does not limit the classes that can be serialized in the proxy. Remote attacker can make a special serialized Java Message Service (JMS) ObjectMessage objects exploit this vulnerability to execute arbitrary code.

Reference Links:

<https://www.blackhat.com/docs/us-16/materials/us-16-Kaiser-Pwning-Your-Java-Messaging-With-Deserialization-Vulnerabilities.pdf>

Vulnerability environment

Start the vulnerable environment:

docker compose up -d

After running the environment, it will establish two ports on port 61616 and 8161. Port 61616 is the working port, and messages are delivered on this port. Port 8161 is the webpage management page port. Access <http://your-ip:8161> , You can see the network management page, but this vulnerability does not require a network theoretically.